



5CM512 Communication and Security Protocols

Week 4: Enhanced Electronic Email Security

Enhanced security services

RFC 2634 defines four enhanced security services for S/MIME:

Signed receipts

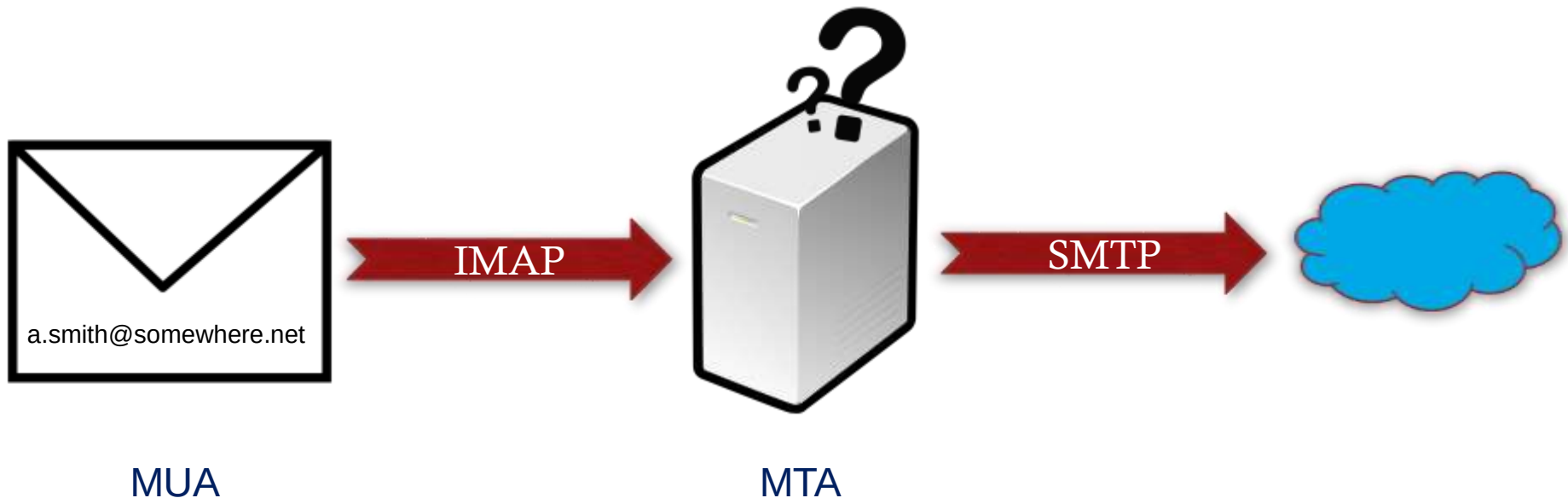
Security labels

Secure mailing lists

Signing certificates

Class discussion

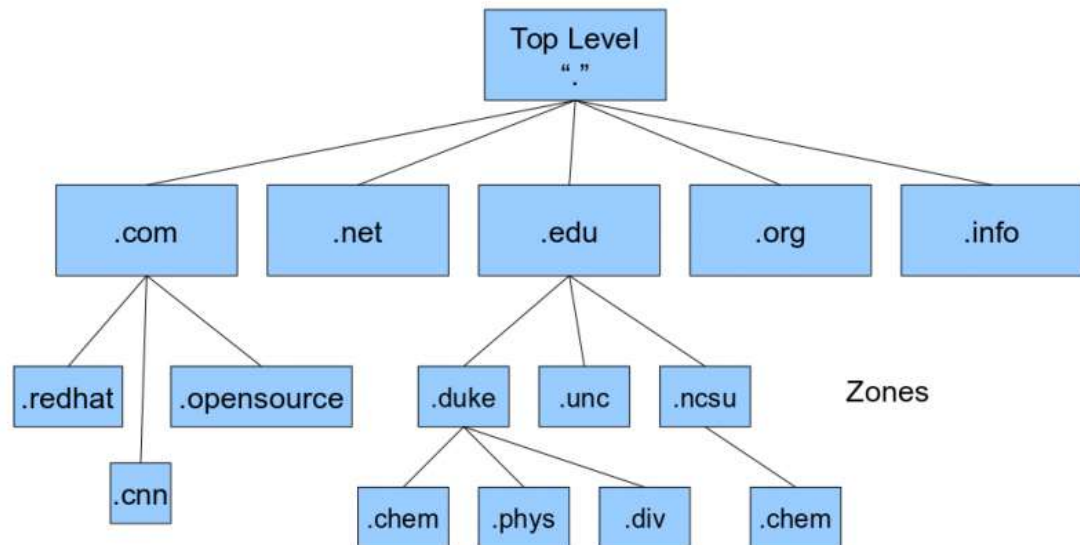
- How can MUA and MTU resolve the recipient address ?



DOMAIN NAME SYSTEM (DNS)

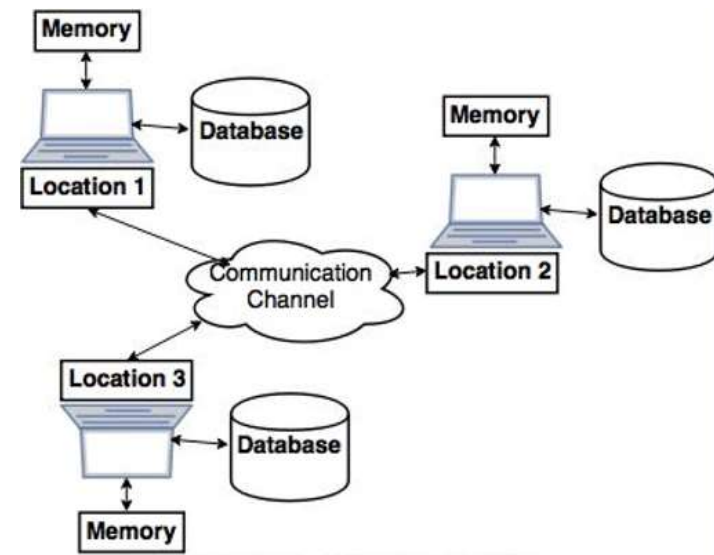


- A directory lookup service
 - provides a mapping between the name of a host on the Internet and its numeric IP address
- Essential to the functioning of the Internet
- Used by MUAs and MTAs to find the address of the next hop server for mail delivery
- Uses a tree-structured name space to identify resources on the Internet



DNS DATABASE

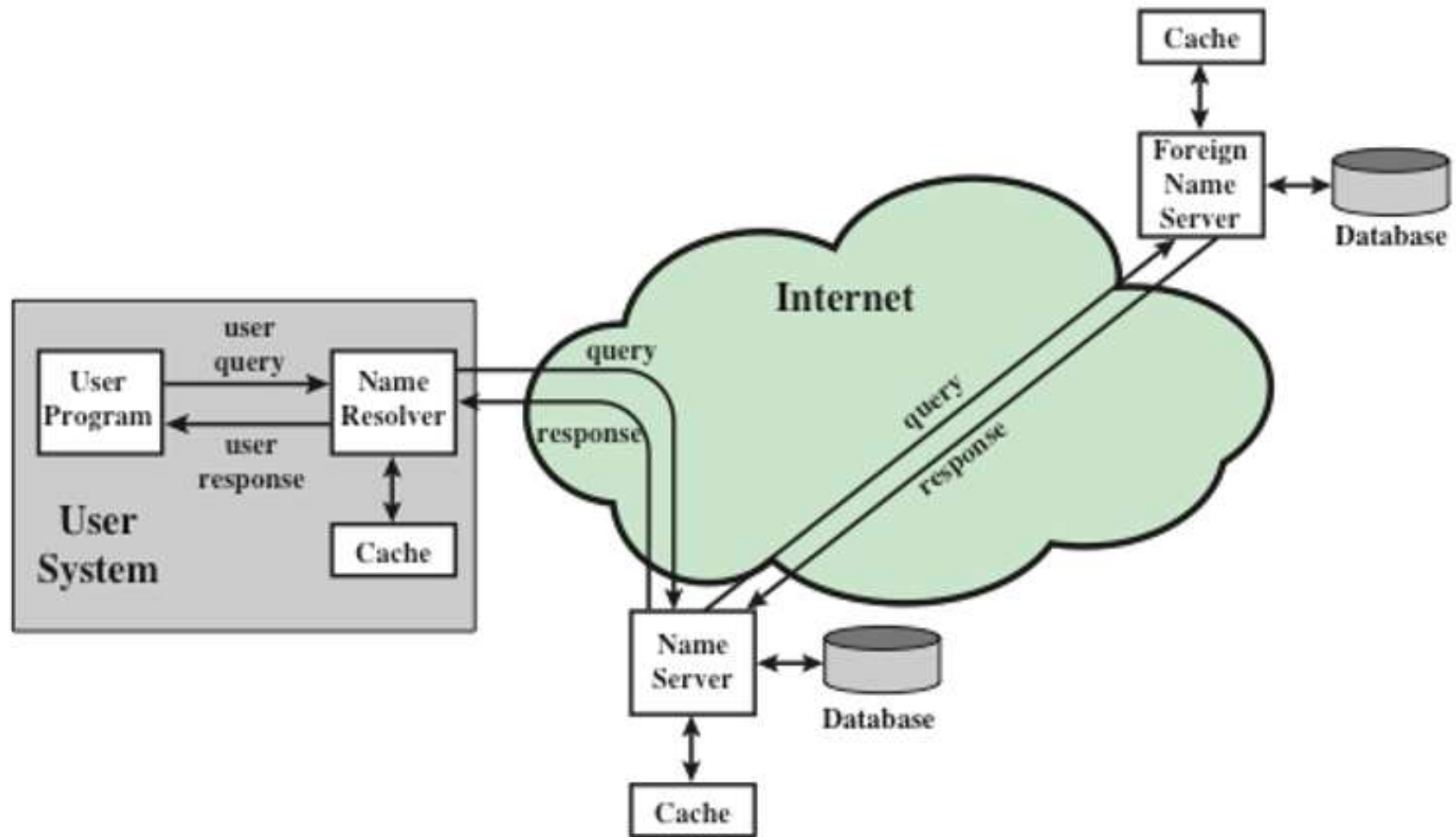
- DNS is based on a hierarchical database
 - containing resource records (RRs)
 - include the name, IP address, and other information about hosts
- Key features of the database:
 - Variable-depth hierarchy for names
 - DNS allows essentially unlimited levels and uses the period (.) as the level delimiter in printed names
 - Distributed database
 - The database resides in DNS servers scattered throughout the Internet
 - Distribution controlled by the database
 - The DNS database is divided into thousands of separately managed zones, which are managed by separate administrators



Resource Records Types

Type	Description
A	A host address. This RR type maps the name of a system to its IPv4 address. Some systems (e.g., routers) have multiple addresses, and there is a separate RR for each.
AAAA	Similar to A type, but for IPv6 addresses.
CNAME	Canonical name. Specifies an alias name for a host and maps this to the canonical (true) name.
HINFO	Host information. Designates the processor and operating system used by the host.
MINFO	Mailbox or mail list information. Maps a mailbox or mail list name to a host name.
MX	Mail exchange. Identifies the system(s) via which mail to the queried domain name should be relayed.
NS	Authoritative name server for this domain.
PTR	Domain name pointer. Points to another part of the domain name space.
SOA	Start of a zone of authority (which part of naming hierarchy is implemented). Includes parameters related to this zone.
SRV	For a given service provides name of server or servers in domain that provide that service.
TXT	Arbitrary text. Provides a way to add text comments to the database.
WKS	Well-known services. May list the application services available at this host.

DNS NAME RESOLUTION



Class discussion

- Can DNS create any security threats and risks?
- If so, what are they?



DNS RELATED SECURITY RISKS

- Registrar or Domain hijacking
- Typosquatting
- Cache poisoning

Registrar or Domain hijacking



typosquatting

Examples of Typosquatting

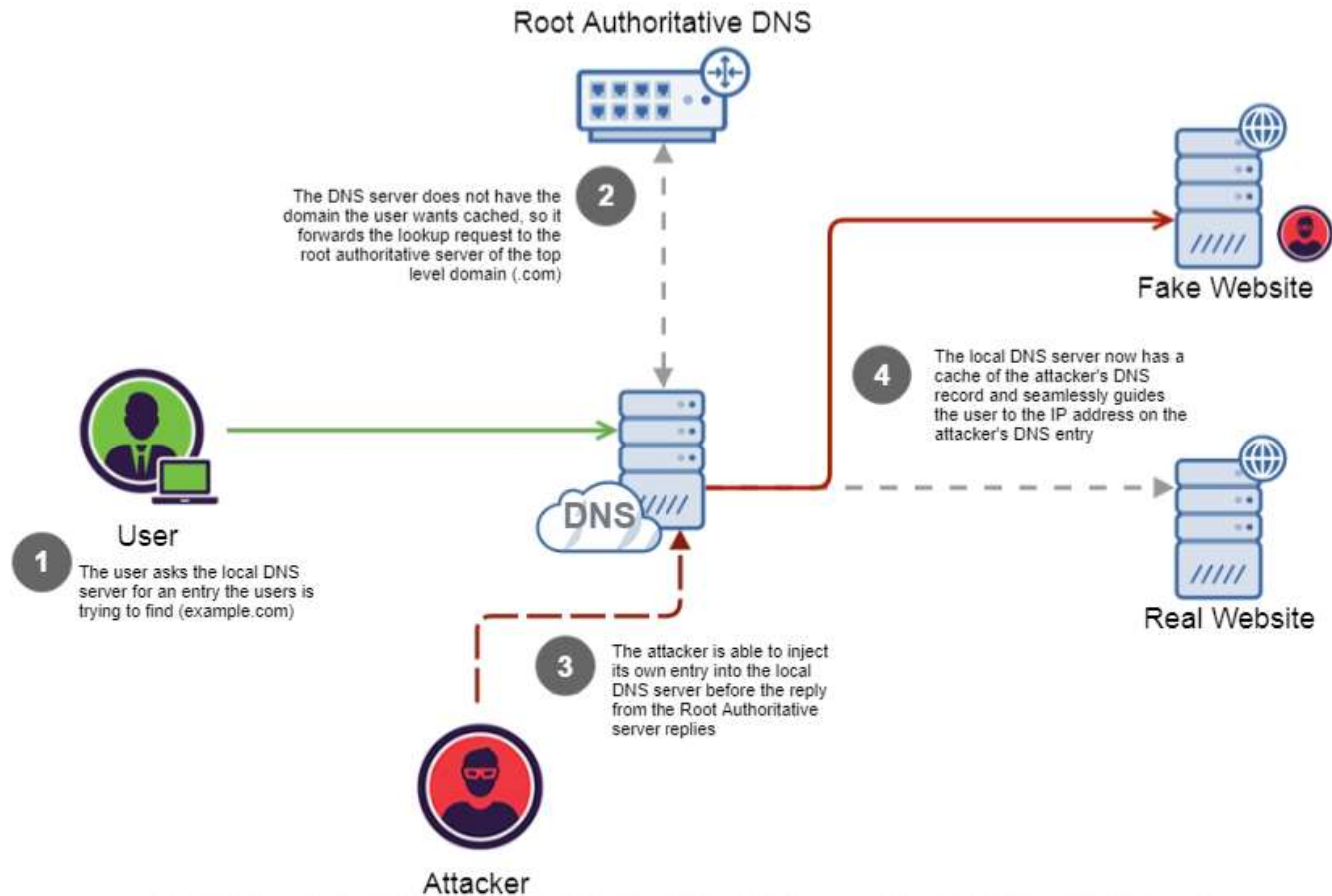
Real Domain Targeted	Typosquat Domain Example
www.github.com	www.gIthub.com
www.google.com	www.gougle.com
www.amazon.com	www.amozon.com
www.victoriasscret.com	www.victoriasecret.com
www.homedepot.com	www.homdepot.com

Typos

Missing an 'S'

Letters reversed

Cache poisoning



SOLUTION

DNSSEC

DNS SECURITY EXTENSIONS



- DNSSEC:
 - Provides end-to-end protection through the use of digital signatures
 - Created by responding zone administrators and verified by a recipient's resolver software
 - Avoids the need to trust intermediate name servers and resolvers
 - Consists of a set of new resource record types and modifications to the existing DNS protocol
- Defined in:
 - RFC 4033, *DNS Security Introduction and Requirements*
 - RFC 4034, *Resource Records for the DNS Security Extensions*
 - RFC 4035, *Protocol Modifications for the DNS Security Extensions*

DNS-BASED AUTHENTICATION OF NAMED ENTITIES (DANE)

- DANE
 - A protocol
 - allows X.509 certificates to be bound to DNS names using DNSSEC
 - Purpose
 - to replace reliance on the security of the certificate authority (CA) system with reliance on the security provided by DNSSEC
 - Defines a new DNS record type, TLSA
 - can be used for a secure method of authenticating SSL/TLS certificates

TLSA RR Transmission Format



SENDER POLICY FRAMEWORK (SPF)

- SPF is the standardized way for a sending domain to identify and assert the mail senders for a given domain
- Addresses the problem of any host being able to use any domain name for each of the various identifiers in the mail header, not just the domain name where the host is located
- Defined in RFC 7208
- SPF works by checking a sender's IP address against the policy encoded in any SPF record found at the sending domain

Example in which SMTP Envelope Header does not Match Message Header

```
S: 220 foo.com Simple Mail Transfer Service Ready
C: HELO mta.example.net
S: 250 OK
C: MAIL FROM:<alice@example.org>
S: 250 OK
C: RCPT TO:<Jones@foo.com>
S: 250 OK
C: DATA
S: 354 Start mail input; end with <cr><lf>.<cr><lf>
C: To: bob@foo.com
C: From: alice.sender@example.net
C: Date: Today
C: Subject: Meeting Today
. . .
```

Common SPF Mechanisms and Modifiers

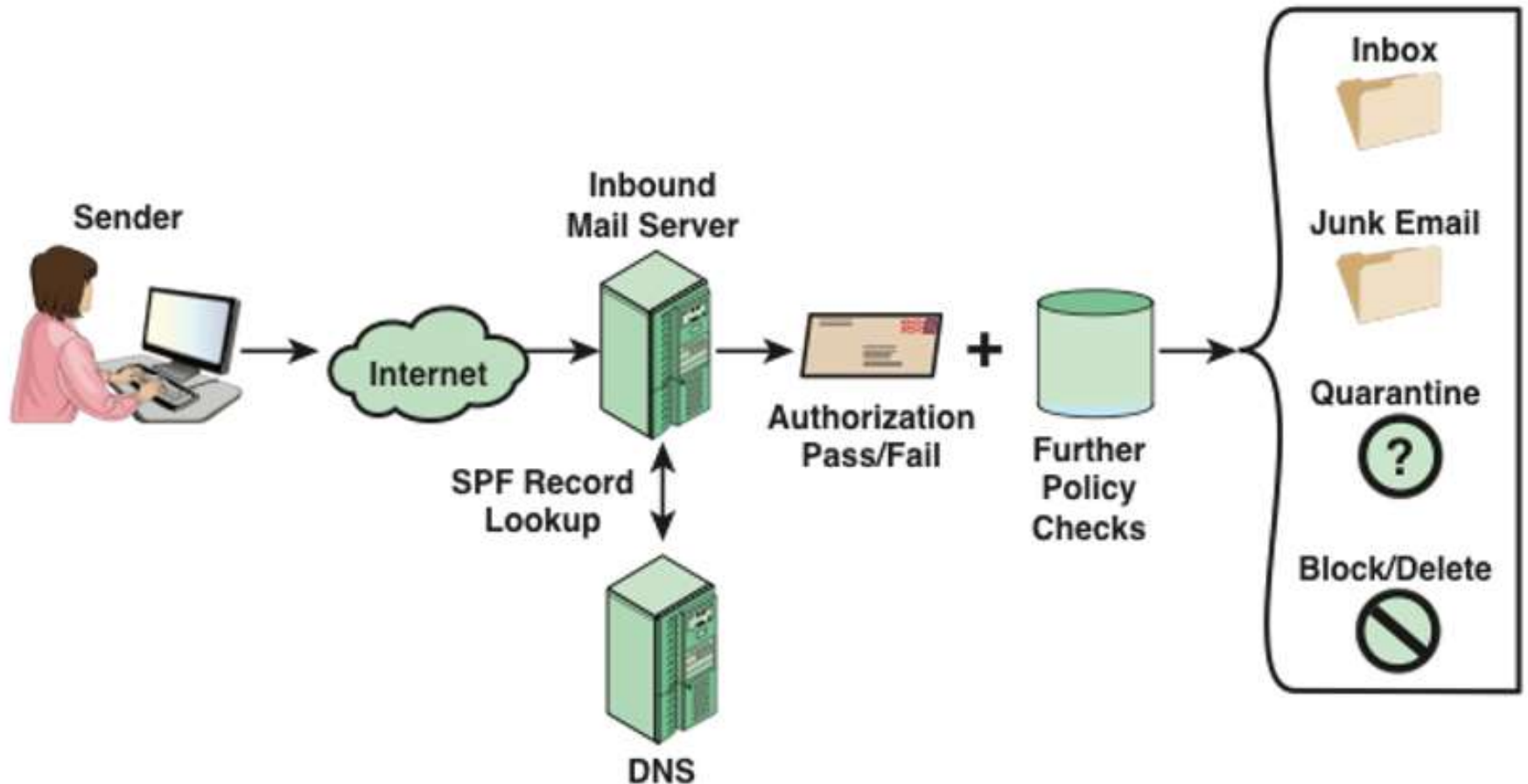
Tag	Description
ip4	Specifies an IPv4 address or range of addresses that are authorized senders for a domain.
ip6	Specifies an IPv6 address or range of addresses that are authorized senders for a domain.
mx	Asserts that the listed hosts for the Mail Exchange RRs are also valid senders for the domain.
include	Lists another domain where the receiver should look for an SPF RR for further senders. This can be useful for large organizations with many domains or sub-domains that have a single set of shared senders. The include mechanism is recursive, in that the SPF check in the record found is tested in its entirety before proceeding. It is not simply a concatenation of the checks.
all	Matches every IP address that has not otherwise been matched.

(a) SPF Mechanisms

Modifier	Description
+	The given mechanism check must pass. This is the default mechanism and does not need to be explicitly listed.
—	The given mechanism is not allowed to send e-mail on behalf of the domain.
~	The given mechanism is in transition and if an e-mail is seen from the listed host/IP address, then it should be accepted but marked for closer inspection.
?	The SPF RR explicitly states nothing about the mechanism. In this case, the default behavior is to accept the e-mail. (This makes it equivalent to '+' unless some sort of discrete or aggregate message review is conducted.)

(b) SPF Mechanism Modifiers

SENDER POLICY FRAMEWORK OPERATION



Any QUESTIONS?

